

Diagnóstico de Seguridad

Activum Inside — Revista Interna Digital

CONFIDENCIAL — USO INTERNO

Aplicación: Activum Inside · Edición Nº 1 (junio 2026)
Fecha del diagnóstico: 16 de junio de 2026
Alcance: Código fuente completo, infraestructura de hosting, flujos de datos

Diagnóstico de Seguridad — Activum Inside

Aplicación: Activum Inside · Revista Interna Digital **Versión analizada:** Edición Nº1 (junio 2026) **Fecha del diagnóstico:** 16 de junio de 2026 **Alcance:** Código fuente completo, infraestructura de hosting, flujos de datos **Clasificación:** Uso interno — Confidencial

1. Resumen Ejecutivo

Activum Inside es una aplicación web estática de uso interno, sin backend propio ni base de datos. Todo el procesamiento ocurre en el navegador del usuario. Su perfil de riesgo es **bajo-moderado** para una herramienta interna, con los siguientes matices:

Área	Nivel de riesgo	Motivo principal
Autenticación	Alto	No existe control de acceso
Integridad de datos	Medio	Edición de HTML sin sanitizar
Privacidad / RGPD	Medio	Google Fonts y Vercel transfieren datos a EE. UU.
Formularios	Bajo-Medio	Datos viajan por el cliente de correo del usuario
Almacenamiento local	Bajo	`localStorage`, solo en el navegador del usuario
Dependencias	Bajo	Versiones conocidas, sin CVE activos relevantes
Red y transporte	Bajo	Vercel sirve con HTTPS y TLS 1.3 por defecto

Recomendación prioritaria: Restringir el acceso a la URL mediante autenticación (SSO corporativo o protección por contraseña en Vercel) antes de compartir el enlace de producción. Sin ello, cualquier persona con la URL puede leer **y editar** todo el contenido.

2. Inventario de Datos y Flujos

2.1 Datos que procesa la aplicación

Tipo de dato	Origen	Destino	¿Sale del dispositivo del usuario?
Imágenes subidas (foto de portada, galería...)	Usuario	`localStorage` del navegador	No
Textos editados (titulares, cuerpos de noticia)	Usuario	`localStorage` del navegador	No
Vista activa (sección actual)	Navegación	`localStorage` → clave `inside_view`	No
Estado del modo edición	Toggle	`localStorage` → clave `inside_editing`	No
Aportación al buzón (nombre, tipo, mensaje)	Formulario	Cliente de correo del usuario → `comunicacion@activum.es`	Sí, vía correo electrónico
IP del usuario	Navegador	Google Fonts API (carga de fuentes)	Sí, a servidores de Google
IP del usuario	Navegador	Vercel (CDN / hosting)	Sí, a servidores Vercel

2.2 Flujo del formulario Activum Lab

```

Usuario rellena formulario en el navegador
↓
JavaScript construye URI: mailto:comunicacion@activum.es?subject=...&body=...
↓
Se abre el cliente de correo del usuario (Outlook, Gmail...)
↓
El usuario pulsa "Enviar" voluntariamente
↓
El correo sale desde la cuenta personal del empleado
↓
Llega a la bandeja de entrada de comunicacion@activum.es

```

Implicaciones: Los datos del formulario (nombre, tipo, mensaje) nunca tocan ningún servidor de Activum Inside. Se procesan como un correo electrónico ordinario, sujeto a las mismas políticas que cualquier email corporativo.

2.3 Claves de `localStorage` generadas

Clave	Contenido	Sensibilidad
`activum_inside:image-slots.state.json`	JSON con imágenes en base64 (WebP, máx. 1 200 px)	Media (fotos corporativas)
`activum_inside:text-edits.state.json`	JSON con HTML editado por el usuario	Baja (contenido de newsletter)
`inside_view`	String: sección activa (`portada`, `apertura`...)	Ninguna
`inside_editing`	`"1"` o `"0"`	Ninguna

3. Cumplimiento RGPD y LOPD-GDD

3.1 Base normativa aplicable

- **RGPD:** Reglamento (UE) 2016/679 del Parlamento Europeo, de 27 de abril de 2016.
- **LOPD-GDD:** Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales.
- **AEPD:** Agencia Española de Protección de Datos, autoridad de control competente.

3.2 Análisis por tratamiento

A) Tratamiento de datos de empleados en el formulario (Activum Lab)

Aspecto	Análisis
Categoría del dato	Datos identificativos (nombre) y datos de opinión del empleado
Base legal	Art. 6.1.f RGPD — Interés legítimo del responsable (gestión de la participación interna)
Responsable del tratamiento	Activum (la empresa), a través del equipo de Comunicación
Encargados del tratamiento	El proveedor de correo corporativo (Microsoft 365 / Google Workspace)
Información al interesado	**Deficiencia:** no existe cláusula informativa en el formulario sobre el tratamiento de los datos enviados
Derechos	El empleado puede ejercer ARSLOP (Acceso, Rectificación, Supresión, Limitación, Oposición, Portabilidad) ante el DPO o el responsable de Comunicación
Retención	No definida en la aplicación. Debe determinarse por la política de correo corporativo de Activum
Transferencia internacional	Solo si el correo corporativo usa servidores fuera del EEE (por ejemplo, Microsoft 365 con centros de datos en EE. UU.)

Acción requerida: Añadir en el formulario una cláusula informativa breve antes del botón "Enviar propuesta", conforme al Art. 13 RGPD. Ejemplo:

Los datos facilitados serán tratados por Activum para gestionar tu participación en la revista interna. Base legal: interés legítimo. Puedes ejercer tus derechos en [correo DPO o responsable]. Más información en nuestra Política de Privacidad.

B) Tratamiento de imágenes (fotos subidas por el usuario)

Aspecto	Análisis
Categoría del dato	Imágenes que pueden contener personas identificables
Dónde se almacena	`localStorage` del navegador del usuario. **No hay servidor.**
Base legal	No aplica tratamiento por parte de Activum: el dato no sale del dispositivo del usuario salvo que él mismo lo gestione
Riesgo	Si un empleado sube una foto de un tercero (compañero), ese tercero debería haber prestado consentimiento según Art. 6.1.a RGPD
Recomendación	Incluir en la guía de uso de la aplicación una indicación sobre el uso de imágenes con personas: solo imágenes con consentimiento previo

C) Google Fonts

Aspecto	Análisis
Servicio	Google Fonts API → fuente Albert Sans cargada desde `fonts.googleapis.com`
Dato transmitido	Dirección IP del navegador del usuario en cada carga de página
Destinatario	Google LLC (EE. UU.)
Base legal	Art. 6.1.f RGPD — Interés legítimo. La fuente se carga solo para mejorar la experiencia visual
Transferencia internacional	Posible transferencia a EE. UU. Google se acoge al marco EU-US Data Privacy Framework (adecuación desde julio 2023)
Riesgo	Bajo, pero debería reflejarse en el Registro de Actividades de Tratamiento (RAT) de Activum
Mitigación posible	Añadir Albert Sans a `vendor/` junto con React y servir en local. Eliminaría esta transferencia completamente

D) Vercel (Hosting)

Aspecto	Análisis
Proveedor	Vercel Inc., con sede en San Francisco, CA (EE. UU.)
Datos transmitidos	IPs de usuarios, cabeceras HTTP, logs de acceso
Marco de adecuación	EU-US Data Privacy Framework (Vercel figura en la lista certificada)
DPA (Acuerdo de Encargado)	**Verificar:** Vercel ofrece DPA en sus términos Pro/Enterprise. Con el plan gratuito no es automático
Ubicación de servidores	Por defecto, región más próxima (puede ser Europa). Configurable en `vercel.json`
Logs	Vercel retiene logs de acceso según su política de privacidad (30 días en plan gratuito)
Recomendación	Suscribir el DPA de Vercel, configurar región `fra1` (Frankfurt) o `dub1` (Dublín) para garantizar que los datos permanecen en el EEE

3.3 Registro de Actividades de Tratamiento (RAT)

Conforme al Art. 30 RGPD, Activum debe incluir en su RAT el tratamiento asociado a Activum Inside:

Nombre del tratamiento: Revista interna digital Activum Inside
 Responsable: [Razón social Activum] – [NIF]
 Representante: [Nombre DPO o contacto RGPD]
 Finalidad: Comunicación interna corporativa
 Categorías de datos: Identificativos (nombre), opiniones e imágenes de empleados
 Categorías interesados: Empleados de Activum
 Destinatarios: Equipo de Comunicación interno
 Transferencias internas: No aplica
 Transferencias intern.: Vercel Inc. (hosting), Google LLC (fuentes web)
 Plazos supresión: Según política de correo corporativo para aportaciones; localStorage se borra con el navegador del usuario
 Medidas de seguridad: HTTPS, localStorage client-side, sin base de datos

4. Características de Seguridad del Hosting (Vercel)

4.1 Protecciones activas por defecto

Protección	Estado	Detalle
HTTPS / TLS	Activo	TLS 1.2 / 1.3. Certificado Let's Encrypt gestionado automáticamente
HTTP → HTTPS redirect	Activo	Vercel redirige todo el tráfico HTTP a HTTPS
HSTS	Activo	`Strict-Transport-Security: max-age=63072000`
DDoS protection	Activo	Protección de capa 3/4 incluida en todos los planes
CDN global	Activo	Edge Network en 100+ regiones; mitiga ataques de volumetría
Aislamiento de despliegues	Activo	Cada deploy es inmutable; rollback instantáneo

4.2 Cabeceras de seguridad HTTP — Estado actual

Cabecera	Estado	Riesgo
`Content-Security-Policy`	No configurada	Medio — permite carga de recursos arbitrarios
`X-Frame-Options`	No configurada	Bajo — clickjacking posible si se incrusta en iframe
`X-Content-Type-Options`	No configurada	Bajo — MIME sniffing posible
`Referrer-Policy`	No configurada	Bajo — la URL se envía al navegar a externos
`Permissions-Policy`	No configurada	Bajo — sin restricción de APIs del navegador
`Cross-Origin-Opener-Policy`	No configurada	Bajo

Cómo solucionarlo: Añadir en `vercel.json`:

```
{
  "buildCommand": null,
  "headers": [
    {
      "source": "/(.*)",
      "headers": [
        { "key": "X-Frame-Options", "value": "SAMEORIGIN" },
        { "key": "X-Content-Type-Options", "value": "nosniff" },
        { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
        { "key": "Permissions-Policy", "value": "camera=(), microphone=(), geolocation=()" },
        { "key": "Content-Security-Policy", "value": "default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com; img-src 'self' data:; connect-src 'self';" }
      ]
    }
  ]
}
```

4.3 Configuración de región (dato crítico RGPD)

Actualmente `vercel.json` no especifica región. Para garantizar que los datos de los usuarios europeos permanecen en el EEE:

```
{
  "regions": ["fra1"]
}
```

`fra1` = Frankfurt (Alemania). Alternativas: `dub1` (Dublín), `cdg1` (París).

5. Seguridad de la Aplicación

5.1 Control de acceso

Mecanismo	Estado
Autenticación de usuarios	**No existe**
Autorización (roles)	**No existe**
Sesiones o tokens	**No existe**
Restricción por IP	No configurada
Contraseña de acceso	No configurada

Impacto: Cualquier persona que conozca la URL puede:

1. Leer todo el contenido (newsletters, datos de empleados, información de La Nucía One)
2. Activar el modo edición (tecleando en la consola del navegador: `localStorage.setItem('inside_editing','1')`)
3. Modificar textos e imágenes de forma persistente en su sesión local

Solución inmediata en Vercel (sin código): Activar *Password Protection* en el dashboard de Vercel (Settings → Security → Password Protection). Requiere plan Pro (20 \$/mes). Alternativa gratuita: Cloudflare Access (SSO o contraseña).

Solución recomendada a medio plazo: Integrar el SSO corporativo de Activum (Microsoft Entra ID / Azure AD) mediante Cloudflare Access o un proxy autenticado.

5.2 Modo edición — Riesgo de modificación no autorizada

El modo edición se activa con un botón flotante cuando `window.omelette.writeFile` existe (inyectado por el polyfill). Cualquier usuario autenticado en la app puede:

- Activar edición con el botón "✎ Editar textos"
- Modificar cualquier texto de cualquier sección
- Subir imágenes a cualquier hueco

Los cambios se guardan en el `localStorage` del navegador del usuario, no en un servidor centralizado. Esto significa que:

- Los cambios son **locales**, no afectan a otros usuarios
- No hay riesgo de desfiguración (defacement) global
- Pero en un navegador compartido (quiosco, sala de reuniones), el siguiente usuario hereda los cambios

Recomendación: Separar el rol editor (equipo de Comunicación, con acceso al código fuente) del rol lector (resto de empleados). El botón de edición debería suprimirse en producción o protegerse con una contraseña adicional.

5.3 Vulnerabilidades de código (XSS)

Punto	Tipo	Código	Severidad
Restauración de textos editados	**Stored XSS potencial**	<code>`el.innerHTML = store[tid]`</code> (index.html:231)	Media
Imágenes almacenadas	**Sin riesgo**	Valida <code>`data:image/`</code> antes de renderizar (image-slot.js:605)	—
Formulario buzón	**Sin riesgo directo**	URI-encodeado con <code>`encodeURIComponent`</code>	—

Stored XSS en edición de textos: Si un atacante con acceso al archivo `.text-edits.state.json` (solo en entorno de diseño, no en producción con el polyfill) inyectara HTML malicioso, se ejecutaría en el navegador de cualquier usuario. En producción, el almacenamiento es `localStorage` individual, por lo que el ataque solo afectaría al propio atacante.

Riesgo real en producción: Bajo (el `localStorage` es por origen y usuario). Sin embargo, si se migrara a almacenamiento centralizado en el futuro, pasaría a ser crítico.

Mitigación recomendada: Sanitizar el HTML antes de aplicarlo, usando DOMPurify:

```
el.innerHTML = DOMPurify.sanitize(store[tid]);
```

5.4 Dependencias y versiones

Librería	Versión	CVEs conocidos	Notas
React	18.3.1	Ninguno activo	Última versión estable de la rama 18
ReactDOM	18.3.1	Ninguno activo	Idem
Babel Standalone	7.29.0	Ninguno activo	Solo se usa para compilar JSX en el navegador

Riesgo adicional de Babel Standalone en producción: Babel Standalone (3 MB) compila JSX en el navegador en tiempo de ejecución. No es una práctica recomendada para producción (lento en dispositivos lentos, superficie de ataque mayor). Lo ideal sería precompilar el JSX con una herramienta de build (Vite, esbuild) y eliminar Babel del bundle.

5.5 Gestión de imágenes

Aspecto	Estado	Detalle
Tipos aceptados	Filtrado	PNG, JPEG, WebP, AVIF. SVG rechazado (puede contener scripts)
Tamaño máximo	Parcial	Redimensiona a 1 200 px máximo, pero no limita el archivo de entrada
Metadatos EXIF	Eliminados	La recodificación a WebP vía Canvas elimina metadatos
Almacenamiento	Local	`localStorage`, no sale del dispositivo
Cuota de almacenamiento	Sin aviso	Si se supera la cuota (~5-10 MB), el error es silencioso

6. Acceso a Datos y Correo Electrónico

6.1 Direcciones de correo expuestas en el código fuente

Las siguientes direcciones están visibles en el HTML renderizado (inspeccionables con F12 o [view-source](#)):

Dirección	Contexto	Riesgo
`rrhh@activum.es`	Sección Wellbeing / El cuerpo también trabaja	Spam / phishing dirigido
`comunicacion@activum.es`	Buzón, Galería, pie de página	Spam / phishing dirigido

Recomendación: Para un portal interno sin acceso público, el riesgo es bajo. Si en algún momento la URL fuera accesible desde internet sin autenticación, estas direcciones podrían ser cosechadas por scrapers de spam.

6.2 Flujo de datos del formulario (Activum Lab)

El formulario no usa backend propio. Los datos recorren este camino:

Navegador del empleado → mailto: URI → Cliente de correo (Outlook) → SMTP de Activum → Bandeja de comunicacion@activum.es

Implicaciones de seguridad:

- El correo podría ser interceptado si el SMTP no usa TLS (depende del servidor de correo de Activum, no de esta app)
- El mensaje queda en la bandeja de comunicacion@activum.es indefinidamente salvo política de retención
- No hay confirmación de recepción al empleado
- No hay cifrado extremo a extremo

Implicaciones RGPD:

- El dato (nombre + opinión) lo procesa el equipo de Comunicación. Deben existir instrucciones de tratamiento y un plazo de supresión definido.

7. Riesgos Identificados — Matriz Consolidada

ID	Riesgo	Probabilidad	Impacto	Severidad	Recomendación
R01	URL pública sin autenticación	Alta	Alto	Crítico	Password Protection en Vercel o SSO
R02	Modo edición accesible por cualquier usuario	Alta	Medio	Alto	Suprimir botón en producción o proteger
R03	Cabeceras HTTP de seguridad ausentes	Media	Medio	Medio	Añadir headers en `vercel.json`
R04	innerHTML sin sanitizar en edición	Baja	Medio	Medio	Integrar DOMPurify
R05	Google Fonts transfiere IP a Google	Alta	Bajo	Bajo	Servir Albert Sans en local
R06	Vercel sin DPA firmado	Media	Medio	Medio	Suscribir DPA de Vercel
R07	Región de Vercel no fijada al EEE	Media	Medio	Medio	Añadir `"regions": ["fra1"]`
R08	Sin cláusula informativa en formulario	Alta	Medio	Medio	Añadir texto informativo RGPD
R09	Babel Standalone en producción	Baja	Bajo	Bajo	Precompilar JSX con Vite/esbuild
R10	Sin límite de tamaño en carga de imágenes	Baja	Bajo	Bajo	Añadir validación de tamaño de archivo
R11	localStorage sin cifrado	Baja	Bajo	Bajo	Aceptable para datos de newsletter
R12	Retención de datos en correo no definida	Media	Bajo	Bajo	Definir política de retención de correos del buzón

8. Recomendaciones Priorizadas**Inmediatas (antes de compartir la URL en producción)****1. Activar autenticación en Vercel**

Settings → Security → Password Protection (requiere plan Pro) o configurar Cloudflare Access con SSO corporativo. Sin esto, la aplicación es accesible para cualquiera que conozca la URL.

1. Fijar región europea en Vercel

Añadir `"regions": ["fra1"]` en `vercel.json` para garantizar que los logs y la entrega de contenido ocurren en el EEE (Art. 44-49 RGPD).

1. Suscribir el DPA de Vercel

Disponible en vercel.com/legal/dpa. Necesario para designar a Vercel como encargado del tratamiento conforme al Art. 28 RGPD.

Corto plazo (próximas 2-4 semanas)

1. Añadir cabeceras de seguridad HTTP

Configurar `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy` y `Content-Security-Policy` en `vercel.json` (ver sección 4.2).

1. Cláusula informativa en el buzón

Añadir un párrafo informativo sobre tratamiento de datos bajo el formulario Activum Lab (ver sección 3.2.A).

1. Incluir en el RAT de Activum

Registrar este tratamiento en el Registro de Actividades de Tratamiento de la empresa (ver sección 3.3).

Medio plazo (próximos 1-3 meses)

1. Eliminar dependencia de Google Fonts

Añadir Albert Sans a `vendor/` (igual que React y Babel) y quitar el `fonts.googleapis.com`. Elimina la transferencia de IP a Google en cada carga.

1. Sanitizar HTML en edición de textos

Integrar DOMPurify antes de aplicar `innerHTML` para prevenir XSS en escenarios futuros.

1. Precompilar JSX

Migrar a Vite o esbuild para eliminar Babel Standalone del bundle de producción. Mejora el rendimiento y reduce la superficie de ataque.

1. Política de retención para correos del buzón

Definir y documentar cada cuánto tiempo se revisan y eliminan los correos recibidos en `comunicacion@activum.es` procedentes del buzón de sugerencias.

9. Checklist de Cumplimiento RGPD/LOPD-GDD

Obligación	Art. RGPD	Estado	Acción
Base legal identificada para cada tratamiento	6	Identificada	Documentar en RAT
Información al interesado en el punto de recogida	13	Ausente en formulario	Añadir cláusula informativa
Registro de Actividades de Tratamiento	30	Pendiente	Incluir entrada en RAT corporativo
Acuerdo con encargados del tratamiento (Vercel)	28	Pendiente	Firmar DPA de Vercel
Medidas de seguridad apropiadas	32	Parcial	Implementar autenticación y cabeceras
Procedimiento de brechas de seguridad	33-34	Corporativo	Verificar que el procedimiento existente cubre esta app
Derechos de los interesados (ARSLOP)	15-22	Ejercibles	Canal de contacto disponible (rrhh/ comunicacion)
Transferencias internacionales documentadas	44-49	Parcial	Documentar Google Fonts y Vercel en RAT
Evaluación de impacto (EIPD)	35	No requerida	No aplica: datos de empleados de bajo riesgo, sin categorías especiales

10. Notas Técnicas Complementarias

Sobre `localStorage` y la privacidad

`localStorage` no es una cookie, pero la AEPD y el RGPD aplican principios similares cuando se usa para rastrear o perfilar usuarios. En este caso:

- No se usa para rastrear ni perfilar
- Los datos almacenados son contenido editorial (imágenes, textos) y preferencias de UI
- No se comparten con terceros
- El usuario puede borrarlos en cualquier momento desde las opciones del navegador

Conclusión: No requiere banner de cookies ni consentimiento específico para `localStorage` en este uso.

Sobre el aislamiento de datos entre usuarios

Dado que el almacenamiento es `localStorage` (por origen, por navegador, por usuario), cada empleado tiene su propia copia de los datos. Esto implica:

- No existe una "fuente de verdad" centralizada para las imágenes y ediciones
- Si el equipo de Comunicación sube imágenes en su navegador, no se propagan a los demás lectores
- Para distribuir contenido definitivo, el flujo correcto es editar el código fuente y hacer un nuevo despliegue

Sobre la eliminación de datos

Para eliminar todos los datos almacenados por la aplicación en un navegador específico:

```
// En la consola del navegador (F12)
Object.keys(localStorage).filter(k => k.startsWith('activum_inside:') || k === 'inside_view' || k === 'inside_editing').forEach(k => localStorage.removeItem(k));
```

Documento generado el 16 de junio de 2026. Válido para la versión analizada de Activum Inside. Debe revisarse ante cambios significativos en la arquitectura o el tratamiento de datos.